

Skill Arena - Phase 4 Document 1

Authentication, Session Management & Zero Trust Security Architecture

Document Purpose

Define the identity, authentication and session security architecture for the entire Skill Arena ecosystem.

Business Objective

Ensure only authorized users gain access while preventing account compromise, session hijacking and unauthorized activity.

Security Philosophy

Client Trust Level = Zero. Every request must be authenticated, validated and authorized.

Zero Trust Architecture

No user, device, session or service is trusted automatically. Verification occurs continuously.

Identity Management

Central identity service responsible for registration, authentication, authorization and account lifecycle management.

Authentication Methods

Email/Password, Multi-Factor Authentication, Device Verification and Future SSO Integrations.

Password Security

Strong password policies, secure hashing, password history controls and breach detection.

Multi-Factor Authentication

Support authenticator apps, email verification and future hardware security methods.

Session Architecture

Short-lived access tokens and longer-lived refresh tokens with revocation support.

Session Lifecycle

Authentication → Token Issuance → Validation → Refresh → Expiry → Revocation.

Device Management

Track trusted devices, suspicious devices and device verification status.

Device Fingerprinting

Generate risk profiles based on device characteristics and behaviour.

Login Security

Rate limiting, brute-force protection, credential stuffing detection and anomaly monitoring.

Authorization Framework

Role-based and permission-based access controls across all platform services.

User Roles

Player, Premium Player, Moderator, Support Agent, Compliance Officer, Finance Officer and Administrator.

Permission Validation

Permissions verified server-side for every protected operation.

Account Recovery

Secure password recovery, account recovery workflows and identity validation.

Suspicious Login Detection

Detect unusual locations, devices, timing patterns and behavioural anomalies.

Session Monitoring

Monitor active sessions, concurrent sessions and unusual activity.

Session Revocation

Immediate revocation capability for compromised sessions and accounts.

Audit Requirements

All authentication, authorization and session events permanently logged.

Compliance Requirements

Support security audits, investigations and regulatory reviews.

Infrastructure Integration

Authentication services integrated with API gateways, CRM systems and treasury services.

Security Requirements

Encryption in transit, encryption at rest and secure secret management.

Performance Requirements

Authentication and session validation must scale to millions of users.

Acceptance Criteria

Every authenticated action is validated, traceable and protected by layered security controls.